

SGSI-UNCP

Guía de Implementación de Controles Críticos (ISO 27002:2022)

Documento Base del Sistema de Gestión
de Seguridad de la Información

Universidad Nacional del Centro del Perú

Índice

- 1 Guía de Implementación de Controles Críticos (ISO 27002:2022)
 - 1.1 Matriz de Controles de Vanguardia
 - 1.2 Acciones de Mejora (Superando el Estándar)
 - 1.3 Mapa de Correlación con la SoA
 - 1.4 Restricción de Confidencialidad y Cumplimiento
 - 1.5 Documentos Relacionados

1. Guía de Implementación de Controles Críticos (ISO 27002:2022)

Organización: Universidad Nacional del Centro del Perú (UNCP) **Aprobado por:** Oficial de Seguridad y Confianza Digital **Basado en:** ISO/IEC 27002:2022 **Alineamiento:** D-SGSI-05 (Declaración de Aplicabilidad), P-SGSI-03 (Gestión de Accesos), P-SGSI-02 (Gestión de Incidentes)

1.1. Matriz de Controles de Vanguardia

Esta tabla detalla los controles priorizados para los activos críticos de la UNCP (ERP ADESA, Campus Virtual, Datos Personales, infraestructura cloud), integrando los atributos de la norma y mejoras de automatización con enfoque Zero Trust.

1.1.1. 1.1 Controles Organizacionales (A.5)

ID	Control	Propósito	Atributos (Tipo/CIA/Concepto)	Guía de Implementación Mejorada (Zero Trust / Automatización)
5.1	Políticas para la seguridad de la información	Establecer directrices de seguridad	Preventivo / CIA / Gobernar	Documental: Las políticas se centralizan en el repositorio documental del SGSI con control de versiones. Se comunican mediante correo institucional y Moodle. Revisión anual por el CGD. Automatización: Integración de feeds de amenazas (OTX, MISP) directamente en el SIEM/WAF para bloquear IPs maliciosas de forma proactiva sin intervención humana. Revisión mensual de nuevas tácticas MITRE ATT&CK. Política: Todo usuario debe aceptar la POL-SGSI-02 al crear su cuenta institucional. Campañas de concientización trimestrales. Zero Trust: Acceso basado en RBAC + MFA obligatorio para personal. Acceso condicional (ubicación, dispositivo, riesgo de sesión). Verificación continua durante toda la sesión.
5.7	Inteligencia de Amenazas	Proporcionar conciencia del entorno de amenazas	Preventivo / CIA / Identificar	
5.10	Uso aceptable de la información y de los activos	Regular el uso correcto de los activos	Preventivo / C / Proteger	
5.15	Control de acceso	Limitar el acceso a información y sistemas	Preventivo / C / Proteger	

ID	Control	Propósito	Atributos (Tipo/CIA/Concepto)	Guía de Implementación Mejorada (Zero Trust / Automatización)
5.16	Gestión de identidades	Gestionar las identidades digitales	Preventivo / C / Proteger	Automatización: IdM centralizado (Keycloak/Azure AD) sincronizado con RRHH (SIGA) y Admisión (ERP ADESA). Creación y baja automatizada de cuentas. Ciclo de vida completo de la identidad. MFA: MFA obligatorio para todo el personal administrativo y docente. FIDO2/llaves de hardware para administradores de sistemas. MFA recomendado para estudiantes. Contractual: Cláusulas de confidencialidad, SLA de seguridad, derecho a auditoría en todos los contratos de proveedores críticos. Evaluación precontractual y periódica según POL-SGSI-04. CSIRT: Equipo de respuesta a incidentes con playbooks documentados. SIEM centralizado con alertas automatizadas. Clasificación de incidentes según impacto (P-SGSI-02). Arquitectura Híbrida: RTO < 1 hora y RPO < 15 minutos para ERP ADESA mediante replicación sincrónica entre el Datacenter local y Huawei Cloud. Pruebas de failover semestrales (P-SGSI-05).
5.17	Autenticación	Verificar la identidad de los usuarios	Preventivo / C / Proteger	
5.19	Seguridad en relaciones con proveedores	Proteger la información accesible por terceros	Preventivo / CIA / Proteger	
5.24	Gestión de incidentes de seguridad	Asegurar la respuesta consistente a incidentes	Detectivo / CIA / Responder	
5.30	Continuidad de la gestión de seguridad	Integrar la seguridad en la continuidad del negocio	Preventivo / CIA / Recuperar	

1.1.2. 1.2 Controles de Personas (A.6)

ID	Control	Propósito	Atributos	Guía de Implementación Mejorada
6.3	Concienciación, educación y formación	Asegurar que el personal conoce sus responsabilidades	Preventivo / C / Proteger	Programa: Curso anual obligatorio de fundamentos de ciberseguridad en Moodle. Simulacros de phishing semestrales. Campañas de concientización mensuales. Programa de capacitación técnica trimestral (P-SGSI-08). VPN + MFA: Acceso remoto obligatorio mediante VPN institucional con MFA. Prohibición de uso de redes Wi-Fi públicas para sistemas críticos. Cifrado obligatorio en dispositivos móviles (POL-SGSI-05).
6.7	Trabajo a distancia	Proteger la información accesada remotamente	Preventivo / CIA / Proteger	

1.1.3. 1.3 Controles Físicos (A.7)

ID	Control	Propósito	Atributos	Guía de Implementación Mejorada
7.1	Perímetros de seguridad física	Prevenir accesos físicos no autorizados	Preventivo / CIA / Proteger	Datacenter: Muros de concreto, puerta blindada, control biométrico + tarjeta, CCTV 24/7 con retención de 90 días, sensor de intrusiones. Campus con perímetro delimitado y control de acceso vehicular/peatonal (POL-SGSI-07). Ambiental: Detección de incendios (VESDA), extinción por gas limpio, control de temperatura (18-24°C) y humedad (40-60 %), UPS con 30 min de autonomía + generador eléctrico para 24h.
7.4	Protección contra amenazas externas y ambientales	Proteger las instalaciones de desastres	Preventivo / CIA / Proteger	

ID	Control	Propósito	Atributos	Guía de Implementación Mejorada
7.7	Escritorio y pantalla limpios	Prevenir la exposición no autorizada de información	Preventivo / C / Proteger	Norma: Documentos confidenciales guardados bajo llave al retirarse. Bloqueo automático de pantalla a los 5 minutos. Prohibición de dejar sesiones abiertas en estaciones desatendidas. Auditorías visuales trimestrales.
7.14	Eliminación segura de activos	Prevenir la recuperación de información de activos dados de baja	Preventivo / CIA / Proteger	NIST SP 800-88: Clear (sobrescritura) para reasignación interna, Purge (degauss/CE) para baja/donación, Destroy (tritución) para medios dañados o confidenciales. Certificado de destrucción emitido (P-SGSI-07).

1.1.4. 1.4 Controles Tecnológicos (A.8)

ID	Control	Propósito	Atributos	Guía de Implementación Mejorada
8.2	Derechos de acceso con privilegios	Restringir el acceso a funciones críticas	Preventivo / CI / Proteger	Zero Trust JIT: Acceso Just-In-Time a cuentas privilegiadas. Los privilegios de DBA en el ERP ADESA se otorgan por tiempo limitado y bajo aprobación MFA. Sesiones auditadas en el SIEM. Rotación de credenciales privilegiadas cada 90 días.
8.8	Gestión de vulnerabilidades técnicas	Prevenir la explotación de vulnerabilidades	Preventivo / CIA / Proteger	Automatización: Escaneo semanal de vulnerabilidades en todos los sistemas (locales y cloud). Parches críticos (CVSS >= 9.0) aplicados en < 48 horas. Escaneo de contenedores e imágenes en el registro. Reporte mensual al CGD.

ID	Control	Propósito	Atributos	Guía de Implementación Mejorada
8.13	Copias de seguridad	Proteger los datos contra pérdida	Preventivo / CIA / Proteger	Regla 3-2-1: Respaldo diario de bases de datos críticas en Huawei Cloud CBR (inmutable). Pruebas de restauración trimestrales. Cifrado en reposo y en tránsito de todos los respaldos (POL-SGSI-03).
8.16	Seguimiento de actividades (Monitoreo)	Detectar comportamientos anómalos	Detectivo / CIA / Detectar	UBA/SIEM: Uso de análisis de comportamiento (User Behavior Analytics) para detectar accesos anómalos. Integración de logs de Huawei Cloud, ERP ADESA, Moodle, firewalls y MDM en el SIEM. Alertas en tiempo real al CSIRT.
8.20	Seguridad de redes	Proteger la información en las redes	Preventivo / CIA / Proteger	ZTNA (Microsegmentación): Aplicación de Zero Trust Network Access para segmentar lógicamente los recursos. Un alumno en la WiFi de la facultad no tiene visibilidad de los servidores de tesorería. Firewall interno entre segmentos académico y administrativo. 802.1X para autenticación de puertos.
8.24	Uso de criptografía	Proteger la confidencialidad e integridad	Preventivo / CIA / Proteger	Cifrado Generalizado: TLS 1.3 en todas las comunicaciones externas. Cifrado en reposo para bases de datos (TDE) y backups. Cifrado de discos (BitLocker/FileVault) en todos los dispositivos móviles institucionales. Política de gestión de claves con rotación anual.

ID	Control	Propósito	Atributos	Guía de Implementación Mejorada
8.25	Ciclo de vida de desarrollo seguro	Integrar seguridad en el desarrollo	Preventivo / CI / Proteger	DevSecOps: Escaneo SAST en cada commit del ERP ADESA. Escaneo DAST trimestral en aplicaciones web. Análisis de dependencias (SBOM) para identificar librerías con CVEs. Pruebas de penetración anuales en aplicaciones críticas (POL-SGSI-01).
8.31	Separación de entornos	Evitar contaminación de datos	Preventivo / CI / Proteger	IaC: Los entornos de desarrollo y pruebas se despliegan como infraestructura como código (Terraform/Ansible). Prohibición de uso de datos reales de producción en entornos no productivos. Datos sintéticos o enmascarados para pruebas.
8.32	Gestión de cambios	Controlar los cambios en los sistemas	Preventivo / CIA / Proteger	ITIL: Cambios clasificados como estándar, normal o emergencia (P-SGSI-04). Evaluación de impacto de seguridad obligatoria para cambios normales. Plan de rollback documentado. CAB quincenal para cambios mayores.

1.2. Acciones de Mejora (Superando el Estándar)

Para que la UNCP alcance el nivel de madurez deseado en el PGTD y se diferencie como institución líder en seguridad digital, se sugieren las siguientes metodologías de mejora continua:

1.2.1. A. Implementación de SOAR (Security Orchestration, Automation, and Response)

- **Concepto:** Superar el SIEM tradicional automatizando la respuesta a incidentes de baja complejidad.
- **Aplicación UNCP:** Si el SIEM detecta un ataque de fuerza bruta contra el VPN, el SOAR instruye automáticamente al Firewall perimetral para bloquear la IP atacante, notifica al Oficial de Seguridad por Teams y abre un ticket de incidente.
- **Madurez esperada:** 60 % de los incidentes de nivel Bajo gestionados de forma automatizada.

1.2.2. B. Adopción de DevSecOps Integral

- **Concepto:** La seguridad no es una fase del desarrollo, es parte integral del flujo CI/CD.
- **Aplicación UNCP:** Integrar herramientas de análisis de dependencias (OWASP Dependency Check, Snyk) para generar el SBOM del Campus Virtual (Moodle) y bloquear el despliegue si se detectan librerías con CVEs de severidad crítica.
- **Madurez esperada:** 100 % de los despliegues escaneados antes de pasar a producción.

1.2.3. C. Estrategia de Salida de Nube (Multi-Cloud / Hybrid Resilience)

- **Concepto:** Evitar el vendor lock-in garantizando que los servicios críticos puedan migrar entre proveedores cloud o al entorno local.
- **Aplicación UNCP:** Mantener la capacidad de mover las cargas de trabajo críticas (ERP ADESA) desde Huawei Cloud hacia un entorno local o una segunda nube pública en menos de 4 horas, mediante el uso de contenedores (Kubernetes) y almacenamiento de datos portable.
- **Madurez esperada:** DRP probado anualmente con conmutación exitosa.

1.2.4. D. Programa de Bug Bounty Interno

- **Concepto:** Incentivar la identificación de vulnerabilidades por parte de la comunidad universitaria.
- **Aplicación UNCP:** Programa limitado a estudiantes de ingeniería de sistemas y personal de la OTI, con reconocimiento y pequeños incentivos por reportes de vulnerabilidades válidos en sistemas institucionales.

1.3. Mapa de Correlación con la SoA

Control de esta Guía	ID en la SoA (D-SGSI-05)	Estado Objetivo 2027
5.1, 5.7, 5.10, 5.15, 5.16, 5.17	Organizacionales (A.5)	Implementado
5.19, 5.24, 5.30	Organizacionales (A.5)	Implementado
6.3, 6.7	Personas (A.6)	Implementado
7.1, 7.4, 7.7, 7.14	Físicos (A.7)	Implementado
8.2, 8.8, 8.13, 8.16, 8.20	Tecnológicos (A.8)	Implementado
8.24, 8.25, 8.31, 8.32	Tecnológicos (A.8)	Implementado

1.4. Restricción de Confidencialidad y Cumplimiento

Todas las recomendaciones contenidas en esta guía están diseñadas para cumplir con la **Ley N° 29733** (Protección de Datos Personales), el **D.L. N° 1412** (Ley de Gobierno Digital), el **D.S. N° 016-2024-JUS** (Reglamento LPDP) y el **D.S. N° 029-2021-PCM** (Reglamento de Gobierno Digital). Este documento es para uso interno de la UNCP; su distribución externa requiere la anonimización de activos específicos y la autorización del Oficial de Seguridad.

1.5. Documentos Relacionados

Código	Nombre
D-SGSI-05	Declaración de Aplicabilidad (SoA)
P-SGSI-03	Gestión de Identidades y Control de Acceso
P-SGSI-02	Marco de Respuesta a Incidentes (CSIRT)

Código	Nombre
P-SGSI-05	Resiliencia y Continuidad en Nube Híbrida
POL-SGSI-01	Política de Desarrollo Seguro
POL-SGSI-07	Política de Seguridad Física
R-SGSI-01	Inventario de Activos de Información
